

ANEXO C (Informativo)

EJEMPLOS DE AMENAZAS COMUNES

La siguiente tabla presenta ejemplos de amenazas comunes. La lista se puede utilizar durante el proceso de valoración de las amenazas. Estas pueden ser deliberadas, accidentales o ambientales (naturales) y pueden dar como resultado, por ejemplo, daño o pérdida de los servicios esenciales. Para cada uno de los tipos de amenazas, la siguiente lista indica los casos en que D (deliberadas), A (accidentales) y E (ambientales) son pertinentes. La letra D se utiliza para todas las acciones deliberadas que tienen como objetivo los activos de la información, A se utiliza para las acciones humanas que pueden dañar accidentalmente los activos de información y E se utiliza para todos los incidentes que no se basa en las acciones humanas. Los grupos de amenazas no están en orden de prioridad.

Tipo	Amenazas	Origen
Daño físico	Fuego	A, D, E
	Daño por agua	A, D, E
	Contaminación	A, D, E
	Accidente importante	A, D, E
	Destrucción del equipo o los medios	A, D, E
	Polvo, corrosión, congelamiento	A, D, E
Eventos naturales	Fenómenos climáticos	E
	Fenómenos sísmicos	E
	Fenómenos volcánicos	E
	Fenómenos meteorológicos	E
	Inundación	E
Pérdida de los servicios esenciales	Falla en el sistema de suministro de agua o de aire acondicionado	A, D
	Pérdida de suministro de energía	A, D, E
	Falla en el equipo de telecomunicaciones	A, D
Perturbación debida a la radiación	Radiación electromagnética	A, D, E
	Radiación térmica	A, D, E
	Impulsos electromagnéticos	A, D, E
Compromiso de la información	Interceptación de señales de interferencia comprometedoras	D
	Espionaje remoto	D
	Escucha encubierta	D
	Hurto de medios o documentos	D
	Hurto de equipo	D
	Recuperación de medios reciclados o desechados	D
	Divulgación	A, D
	Datos provenientes de fuentes no confiables	A, D
	Manipulación con hardware	D
	Manipulación con software	A, D
	Detección de la posición	D
Fallas técnicas	Falla del equipo	A
	Mal funcionamiento del equipo	A
	Saturación del sistema de información	A, D
	Mal funcionamiento del software	A
	Incumplimiento en el mantenimiento del sistema de información	A, D
Acciones no autorizadas	Uso no autorizado del equipo	D
	Copia fraudulenta del software	D
	Uso de software falso o copiado	A, D
	Corrupción de los datos	D
	Procesamiento ilegal de los datos	D
Compromiso de las funciones	Error en el uso	A
	Abuso de derechos	A, D
	Falsificación de derechos	D
	Negación de acciones	D
	Incumplimiento en la disponibilidad del personal	A, D, E

Se recomienda poner atención particular a las fuentes de amenazas humanas. Éstas se desglosan específicamente en la siguiente tabla:

Fuente de amenaza	Motivación	Acciones amenazantes
Pirata informático, intruso ilegal	Reto Ego Rebelión Estatus Dinero	• Piratería • Ingeniería social • Intrusión, accesos forzados al sistema • Acceso no autorizado al sistema
Criminal de la computación	Destrucción de información Divulgación ilegal de información Ganancia monetaria Alteración no autorizada de los datos	• Crimen por computador (por ejemplo, espionaje cibernético) • Acto fraudulento (por ejemplo, repetición, personificación, interceptación) • Soborno de la información • Suplantación de identidad • Intrusión en el sistema
Terrorismo	Chantaje Destrucción Explotación Venganza Ganancia política Cubrimiento de los medios de comunicación	• Bomba/terrorismo • Guerra de la información (<i>warfare</i>) • Ataques contra el sistema (por ejemplo, negación distribuida del servicio) • Penetración en el sistema • Manipulación del sistema
Espionaje industrial (Inteligencia, empresas, gobiernos extranjeros, otros intereses gubernamentales)	Ventaja competitiva Espionaje económico	• Ventaja de defensa • Ventaja Política • Explotación económica • Hurto de información • Intrusión en la privacidad personal • Ingeniería social • Penetración en el sistema • Acceso no autorizado al sistema (acceso a información clasificada, de propiedad y/o relacionada con la tecnología)
Intrusos (empleados con entrenamiento deficiente, descontentos, malintencionados, negligentes, deshonestos o despedidos)	Curiosidad Ego Inteligencia Ganancia monetaria Venganza Errores y omisiones no intencionales) por ejemplo, error en el ingreso de los datos, error de programación)	• Asalto a un empleado • Chantaje • Observar información reservada • Uso inadecuado del computador • Fraude y hurto • Soborno de información • Ingreso de datos falsos o corruptos • Interceptación • Código malicioso do (por ejemplo, virus, bomba lógica, troyano) • Venta de información personal • Errores en el sistema (bugs) • Intrusión al sistema • Sabotaje del sistema • Acceso no autorizado al sistema

ANEXO D (Informativo)

VULNERABILIDADES Y MÉTODOS PARA LA VALORACIÓN DE LA VULNERABILIDAD

D.1 EJEMPLOS DE VULNERABILIDADES

La siguiente tabla presenta ejemplos de vulnerabilidades en diversas áreas de seguridad, e incluye ejemplos de amenazas que pueden explotar estas vulnerabilidades. La lista puede brindar ayuda durante la valoración de las amenazas y vulnerabilidades, con el fin de determinar escenarios pertinentes de incidente. Se hace énfasis en que en algunos casos otras amenazas también pueden tomar ventaja de estas vulnerabilidades.

Tipos	Ejemplos de vulnerabilidades	Ejemplos de amenazas
Hardware	Mantenimiento insuficiente/instalación fallida de los medios de almacenamiento.	Incumplimiento en el mantenimiento del sistema de información
	Ausencia de esquemas de reemplazo periódico.	Destrucción de equipos o de medios.
	Susceptibilidad a la humedad, el polvo y la suciedad.	Polvo, corrosión, congelamiento
	Sensibilidad a la radiación electromagnética	Radiación electromagnética
	Ausencia de un eficiente control de cambios en la configuración	Error en el uso
	Susceptibilidad a las variaciones de voltaje	Pérdida del suministro de energía
	Susceptibilidad a las variaciones de temperatura	Fenómenos meteorológicos
	Almacenamiento sin protección	Hurto de medios o documentos
	Falta de cuidado en la disposición final	Hurto de medios o documentos
	Copia no controlada	Hurto de medios o documentos
Software	Ausencia o insuficiencia de pruebas de software	Abuso de los derechos
	Defectos bien conocidos en el software	Abuso de los derechos
	Ausencia de "terminación de la sesión" cuando se abandona la estación de trabajo	Abuso de los derechos
	Disposición o reutilización de los medios de almacenamiento sin borrado adecuado	Abuso de los derechos
	Ausencia de pistas de auditoría	Abuso de los derechos
	Asignación errada de los derechos de acceso	Abuso de los derechos
	Software ampliamente distribuido	Corrupción de datos
	En términos de tiempo utilización de datos errados en los programas de aplicación	Corrupción de datos
	Interfaz de usuario compleja	Error en el uso
	Ausencia de documentación	Error en el uso
	Configuración incorrecta de parámetros	Error en el uso
	Fechas incorrectas	Error en el uso
	Ausencia de mecanismos de identificación y autenticación, como la autenticación de usuario	Falsificación de derechos

Tipos	Ejemplos de vulnerabilidades	Ejemplos de amenazas
Software	Tablas de contraseñas sin protección	Falsificación de derechos
	Gestión deficiente de las contraseñas	Falsificación de derechos
	Habilitación de servicios innecesarios	Procesamiento ilegal de datos
	Software nuevo o inmaduro	Mal funcionamiento del software
	Especificaciones incompletas o no claras para los desarrolladores	Mal funcionamiento del software
	Ausencia de control de cambios eficaz	Mal funcionamiento del software
	Descarga y uso no controlados de software	Manipulación con software
	Ausencia de copias de respaldo	Manipulación con software
	Ausencia de protección física de la edificación, puertas y ventanas	Hurto de medios o documentos
	Falla en la producción de informes de gestión	Uso no autorizado del equipo
Red	Ausencia de pruebas de envío o recepción de mensajes	Negación de acciones
	Líneas de comunicación sin protección	Escucha encubierta
	Tráfico sensible sin protección	Escucha encubierta
	Conexión deficiente de los cables.	Falla del equipo de telecomunicaciones
	Punto único de falla	Falla del equipo de telecomunicaciones
	Ausencia de identificación y autenticación de emisor y receptor	Falsificación de derechos
	Arquitectura insegura de la red	Espionaje remoto
	Transferencia de contraseñas en claro	Espionaje remoto
	Gestión inadecuada de la red (Tolerancia a fallas en el enrutamiento)	Saturación del sistema de información
	Conexiones de red pública sin protección	Uso no autorizado del equipo
Personal	Ausencia del personal	Incumplimiento en la disponibilidad del personal
	Procedimientos inadecuados de contratación	Destrucción de equipos o medios
	Entrenamiento insuficiente en seguridad	Error en el uso
	Uso incorrecto de software y hardware	Error en el uso
	Falta de conciencia acerca de la seguridad	Error en el uso
	Ausencia de mecanismos de monitoreo	Procesamiento ilegal de los datos
	Trabajo no supervisado del personal externo o de limpieza	Hurto de medios o documentos
	Ausencia de políticas para el uso correcto de los medios de telecomunicaciones y mensajería	Uso no autorizado del equipo
Lugar	Uso inadecuado o descuidado del control de acceso físico a las edificaciones y los recintos	Destrucción de equipo o medios
	Ubicación en un área susceptible de inundación	Inundación
	Red energética inestable	Pérdida del suministro de energía
	Ausencia de protección física de la edificación, puertas y ventanas	Hurto de equipo

Tipos	Ejemplos de vulnerabilidades	Ejemplos de amenazas
Organización	Ausencia de procedimiento formal para el registro y retiro de usuarios	Abuso de los derechos
	Ausencia de proceso formal para la revisión (supervisión) de los derechos de acceso	Abuso de los derechos
	Ausencia o insuficiencia de disposiciones (con respecto a la seguridad) en los contratos con los clientes y/o terceras partes	Abuso de los derechos
	Ausencia de procedimiento de monitoreo de los recursos de procesamiento de información	Abuso de los derechos
	Ausencia de auditorías (supervisiones) regulares	Abuso de los derechos
	Ausencia de procedimientos de identificación y valoración de riesgos	Abuso de los derechos
	Ausencia de reportes de fallas en los registros de administradores y operadores	Abuso de los derechos
	Respuesta inadecuada de mantenimiento del servicio	Incumplimiento en el mantenimiento del sistema de información
	Ausencia de acuerdos de nivel de servicio, o insuficiencia en los mismos.	Incumplimiento en el mantenimiento del sistema de información
	Ausencia de procedimiento de control de cambios	Incumplimiento en el mantenimiento del sistema de información
	Ausencia de procedimiento formal para el control de la documentación del SGSI	Corrupción de datos
	Ausencia de procedimiento formal para la supervisión del registro del SGSI	Corrupción de datos
	Ausencia de procedimiento formal para la autorización de la información disponible al público	Datos provenientes de fuentes no confiables
	Ausencia de asignación adecuada de responsabilidades en la seguridad de la información	Negación de acciones
	Ausencia de planes de continuidad	Falla del equipo
	Ausencia de políticas sobre el uso del correo electrónico	Error en el uso
	Ausencia de procedimientos para la introducción del software en los sistemas operativos	Error en el uso
	Ausencia de registros en las bitácoras (logs) de administrador y operario.	Error en el uso
	Ausencia de procedimientos para el manejo de información clasificada	Error en el uso
	Ausencia de responsabilidades en la seguridad de la información en la descripción de los cargos	Error en el uso
	Ausencia o insuficiencia en las disposiciones (con respecto a la seguridad de la información) en los contratos con los empleados	Procesamiento ilegal de datos
	Ausencia de procesos disciplinarios definidos en el caso de incidentes de seguridad de la información	Hurto de equipo

Tipos	Ejemplos de vulnerabilidades	Ejemplos de amenazas
	Ausencia de política formal sobre la utilización de computadores portátiles	Hurto de equipo
	Ausencia de control de los activos que se encuentran fuera de las instalaciones	Hurto de equipo
	Ausencia o insuficiencia de política sobre limpieza de escritorio y de pantalla	Hurto de medios o documentos
	Ausencia de autorización de los recursos de procesamiento de la información	Hurto de medios o documentos
	Ausencia de mecanismos de monitoreo establecidos para las brechas en la seguridad	Hurto de medios o documentos
	Ausencia de revisiones regulares por parte de la gerencia	Uso no autorizado del equipo
	Ausencia de procedimientos para la presentación de informes sobre las debilidades en la seguridad	Uso no autorizado del equipo
	Ausencia de procedimientos del cumplimiento de las disposiciones con los derechos intelectuales	Uso de software falso o copiado

D.2 MÉTODOS PARA LA VALORACIÓN DE LAS VULNERABILIDADES TÉCNICAS

Se pueden utilizar métodos proactivos tales como las pruebas del sistema de información para identificar las vulnerabilidades que dependen de la importancia del sistema de tecnología de información y telecomunicaciones (TIC), y los recursos disponibles (por ejemplo, fondos asignados, tecnología disponible, personas con las habilidades para realizar pruebas). Los métodos de prueba incluyen los siguientes:

- herramienta automática de exploración de la vulnerabilidad;
- prueba y evaluación de la seguridad;
- pruebas de penetración;
- revisión del código.

La herramienta automática de búsqueda de vulnerabilidades se utiliza para explorar en un grupo de *hosts* o una red, servicios identificados como vulnerables (por ejemplo, el sistema permite el protocolo de transferencia de archivos (FTP) anónimo, retransmisión de correo electrónico – *sendmail relaying*). Conviene anotar, sin embargo, que algunas de las vulnerabilidades potenciales identificadas por la herramienta automática de búsqueda pueden no representar vulnerabilidades reales en el contexto del entorno del sistema. Por ejemplo, algunas de estas herramientas de búsqueda clasifican las vulnerabilidades potenciales sin tener en cuenta el entorno y los requisitos del lugar. Algunas de las vulnerabilidades identificadas por el software automático de búsqueda pueden en realidad no ser vulnerables para un lugar particular pero se pueden configurar de esa manera debido a que su entorno lo exige. De este modo, este método de prueba puede producir falsos positivos.

La prueba y la evaluación de la seguridad es otra técnica que se puede utilizar para identificar vulnerabilidades en el sistema TIC durante el proceso de valoración del riesgo. Incluye el desarrollo y la ejecución de un plan de pruebas (por ejemplo, guía, procedimientos y resultados

esperados de la prueba). El propósito de la prueba de la seguridad del sistema es probar la eficacia de los controles de seguridad de un sistema TIC en la medida en que se apliquen en un entorno operativo. El objetivo es garantizar que los controles que se aplican satisfacen la especificación aprobada de seguridad para el software y el hardware, e implementar la política de seguridad de la organización o cumplir las normas de la industria.

Las pruebas de penetración se puede utilizar para complementar la revisión de los controles de seguridad y garantizar que las diversas facetas del sistema TIC están aseguradas. Las pruebas de penetración, cuando se utiliza en el proceso de valoración de riesgos, se puede utilizar para evaluar la capacidad del sistema TIC para tolerar intentos intencionales de burlar la seguridad del sistema. Su objetivo es someter a prueba el sistema TIC desde el punto de vista de la fuente de una amenaza e identificar las fallas potenciales en los esquemas de protección del sistema.

La revisión del código es la forma más exhaustiva (pero también la más costosas) de valoración de la vulnerabilidad.

Los resultados de estos tipos de pruebas de la seguridad ayudarán a identificar las vulnerabilidades del sistema.

Es importante anotar que las herramientas y técnicas de penetración pueden dar resultados falsos, a menos que la vulnerabilidad sea explotada exitosamente. Para explotar vulnerabilidades particulares, es necesario conocer el sistema/la aplicación/los parches exactos establecidos en el sistema que se somete a prueba. Si no se conocen estos datos en el momento de la prueba, podría no ser posible explotar de manera exitosa la vulnerabilidad particular (por ejemplo, obtener un *remote reverse shell*); sin embargo, aún es posible detener o reiniciar un proceso o sistema probado. En tal caso, el objeto probado se debería considerar también vulnerable.

Los métodos pueden incluir las siguientes actividades:

- entrevistas a personas y usuarios;
- cuestionarios;
- inspección física;
- análisis de documentos.